

A decorative network diagram in the top-left corner, featuring a complex web of interconnected nodes and lines. Some nodes are highlighted with blue circles, and others with blue dots. The lines are thin and gray, creating a mesh-like structure.

Crypto in Practice

A decorative network diagram in the bottom-right corner, similar to the one in the top-left. It shows a network of nodes and lines, with some nodes highlighted in blue. The overall style is clean and modern, with a focus on connectivity and structure.

Where to use Cryptographic algorithms?

- Authentication.
- Authorization.
- Confidentiality.
- Integrity.
- Non-repudiation.

Authentication

Verifying the identity of an entity/user:

- Something they know.
- Something they are.
- Something they have.

Need to check if the information is correct, **without knowing the information.**

Authentication

- Secure Hashing
 - Store the hash of the known information.
- Threat Model (attacker gets access to the hash)
 - Attacker tries to find the information.
 - Attacker tries to guess the information.

Authentication

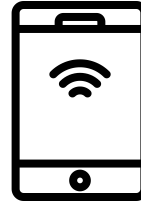
- Secure Hashing
 - Store the hash of the known information.
- What other properties we need?

Authentication

- Secure Hashing
 - Store the hash of the known information.
- Threat Model (attacker gets access to the hash)
 - Attacker tries to find the information.
 - Hash algorithm must be preimage resistant.
 - Attacker tries to guess the information.
 - Hash algorithm must be second preimage resistant.
 - Hash algorithm must be hard for **same-prefix collisions**.

Direct Device Access

Controller accesses device directly.

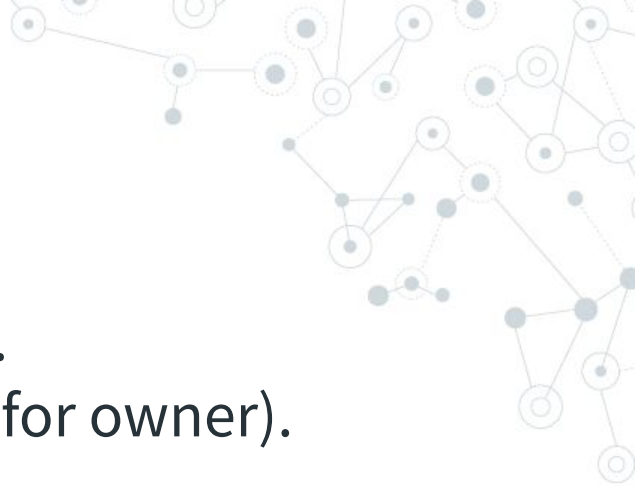


Authentication: Direct Device Access

- User need to prove his/her ownership.

Authentication: Direct Device Access

- User need to prove his/her ownership.



Authentication: Direct Device Access

- User need to prove his/her ownership.
 - Default password (accessible only for owner).
- First login: allow to change the password.

(Is this good?)

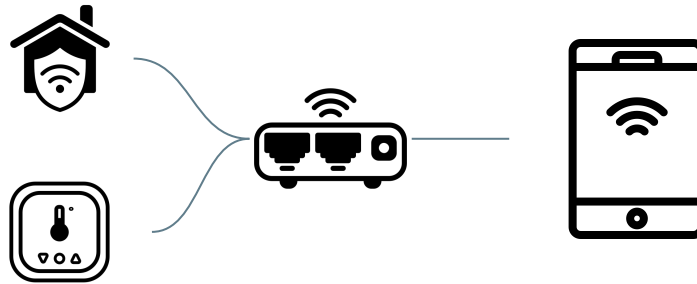


Authentication: Direct Device Access

- User need to prove his/her ownership.
 - Default password (accessible only for owner).
 - **Should be unique for each device.**
- First login: allow to change the password.

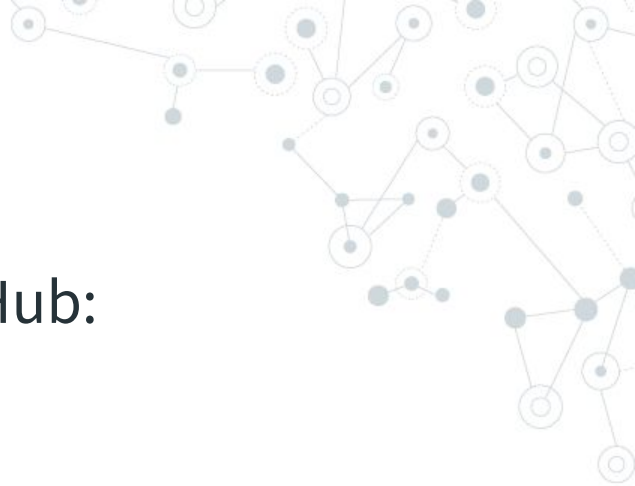
Hub Based Access

Controller accesses device through Hub.



Hub Based Access

- User needs to be authenticated with Hub:
- Hub needs to prove ownership to Device.
- Device needs to prove legitimacy to Hub.



Hub Based Access

- User needs to be authenticated with Hub:
 - OpenID, custom password, etc.
- Hub needs to prove ownership to Device:
 - Proximity (pairing, physical access), Default password, etc.



Device needs to prove legitimacy to Hub.
Device Attestation.

Device Attestation

Prove that device is a legitimate manufacturer device.

Device Attestation

- Prove that device is a legitimate manufacturer device.
 - Public Key Certificates

Device Attestation

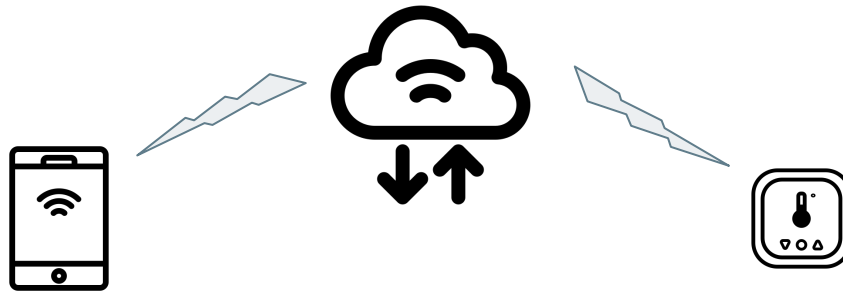
- Prove that device is a legitimate manufacturer device.
 - Public Key Certificates:
 - Manufacturer create a private key for the device and stores them in hardware, e.g., efuses.
 - Creates a certificate (i.e., signs the public key with manufacturer private key) and displays them.

Device Attestation

- Hub receives the certificate -> verifies by using the public key from vendor certificate.
- Hub sends a `AsymEnk(DevPubKey, timestamp||nonce||tempkey)` to device.
- Device sends `SymEnk(tempkey, timestamp||nonce)` to hub.

Cloud Based Access

Controller accesses device through cloud/internet.





Cloud Based Access

- User needs to authenticate with cloud.
- Cloud needs to authenticate with user.
- Cloud needs to authenticate with device.

Device needs to prove its legitimacy with cloud.

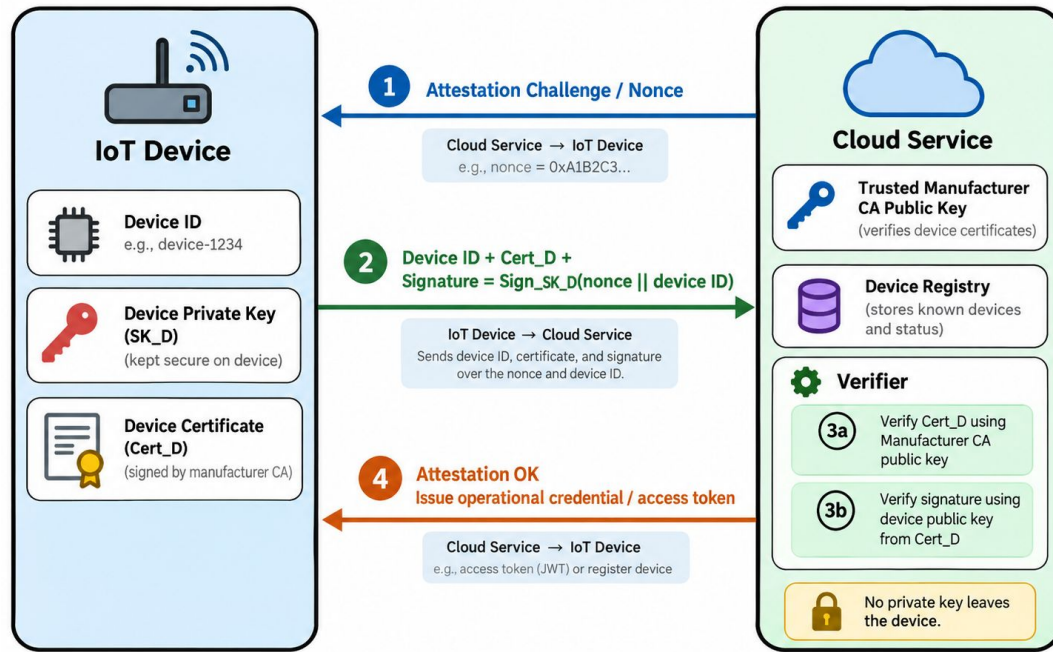




Cloud Based Access

- User needs to authenticate with cloud.
 - Cloud needs to authenticate with user.
 - Cloud needs to authenticate with device.
 - Device needs to prove its legitimacy with cloud:
Device Attestation
- 

Device Attestation with Cloud



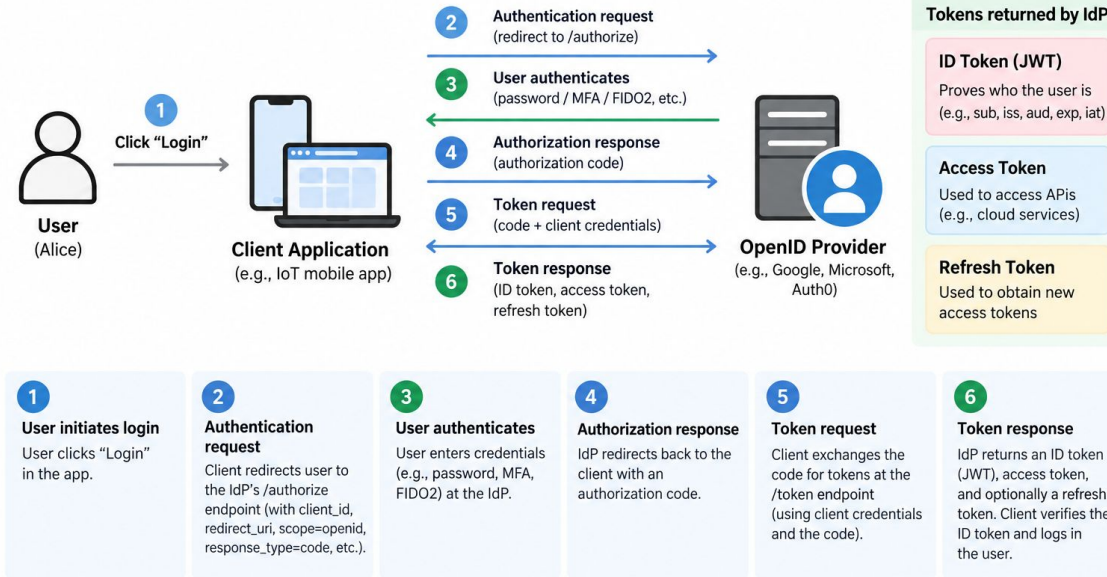
User -> Cloud

- Self hosted authentication.
- Authentication as a service.

Authentication as a Service

- OAuth: Open Authorization (Industry standard for enabling third party access).
- Also provides authentication.
- Examples: Amazon Cognito, Auth0, Firebase Authentication, and Keycloak

OpenID (Oauth 2.0 + ID)



Cloud -> User; Cloud -> Device

Public key certificates!

Authorization

ID -> Capabilities

- Where should we store these?
 - Device? Controller? Hub? Cloud?

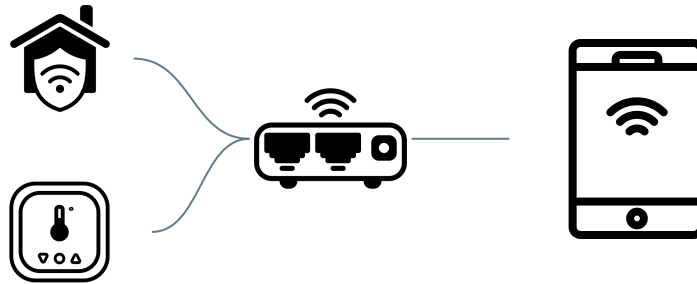
Authorization in Direct Device Access?

Controller accesses device directly.



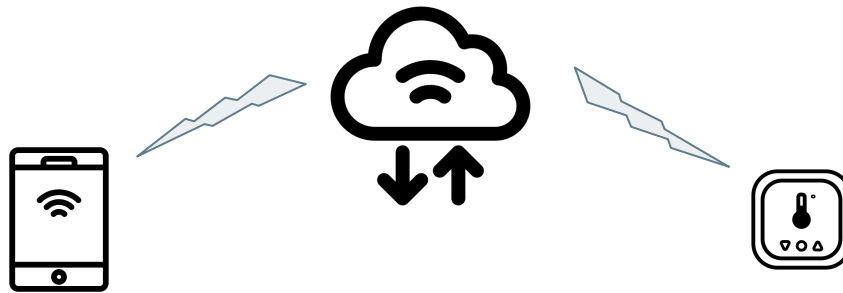
Authorization in Hub Based Access?

Controller accesses device through Hub.



Authorization in Cloud Based Access?

Controller accesses device through cloud/internet.



Authorization on Device

- Device checks and allows the operation (if permitted).

Authorization on Device

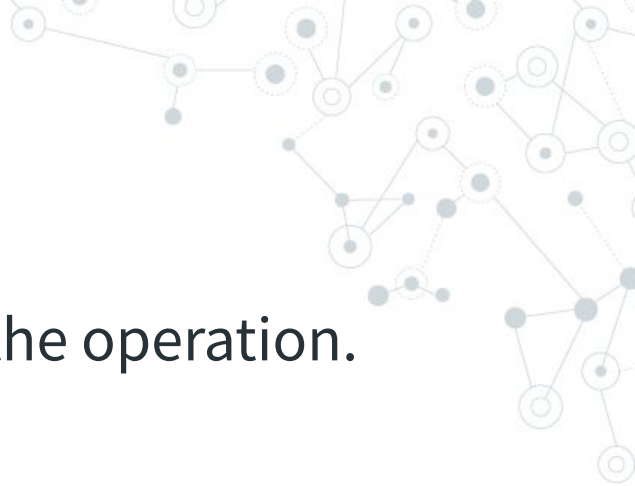
- Single point control.
- Complex architecture.
- Low extensibility.

Authorization on Controller

- Controller (mobile app) checks and allows the operation (if permitted).

Authorization on Controller

- Extensible.
- Bypassable (if talked to device directly).



Authorization on Cloud/Hub

Cloud/Hub checks and allows (or denys) the operation.

Authorization on Cloud/Hub

- Extensible.
- Can use modern schemes.
- Bypassable (if talked to device directly).

Authorization on Device

Keep it simple.

Authorization on Controller

Avoid!

Authorization on Cloud/Hub

- Attacker should not be able to communicate with the device directly.
- Should be carefully implemented! They control multiple devices!

RCE?

Using the private key and certificate pulled from my Shark device I can subscribe to topics on *any* device. This led me to believe that I could publish to them as well. I verify this claim later in the writeup by purchasing a second device and using my original key to publish messages to the new device. I did not publish messages to devices that I did not own. I wrote an interactive MQTT client in Python that allowed me to authenticate to the AWS server with my device certificate and subscribe/publish to different topics.

<https://tokay0.com/posts/millions-of-shark-vacuums-vulnerable-to-rce.html>

Confidentiality

- Encryption with Shared key.

Integrity

- Data + Hash?

Integrity

- Data + **Encrypt (Hash)**